

CYBER SECURITY (S7CSI01)

Unit-1

Dr. Pramod TC
Associate Professor
Dept. of CSE
SIT, Tumkur
pramodtc@sit.ac.in

Cybersecurity Means Different Things to Different Folks

User / Organization	Cybersecurity Means	Example
Individuals	Protecting personal data; keeping devices malware-free	Using antivirus software , enabling two-factor authentication (2FA) for email and banking apps
Small Business Owners	Securing credit card data; protecting customer data; following standards at point-of-sale systems	Using PCI-DSS compliant POS terminals ; encrypting customer payment info
Online Businesses	Protecting servers from untrusted outsiders	Setting up web application firewalls (WAF) ; running secure HTTPS websites
Shared Service Providers	Safeguarding data centers and virtual servers for clients	Implementing intrusion detection systems (IDS) and access control policies in cloud data centers
Government	Classifying data with laws, policies, procedures, technologies	Using Top Secret / Confidential / Public classifications ; employing secure communication networks for defense

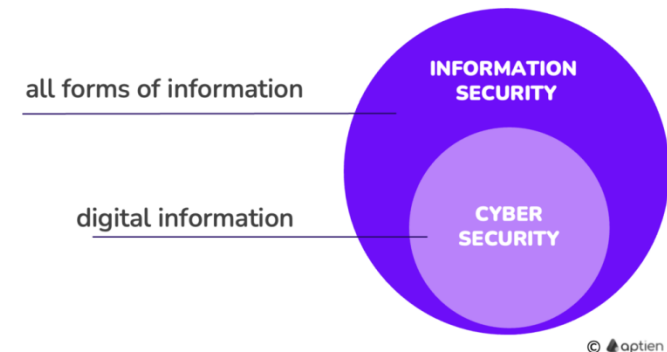
Information security & Cybersecurity

Information security is the broader discipline that protects data in *any form* **digital, physical** (on paper (files, records, documents)), **or even verbal** ((conversations, interviews))).

Ex: personal data stored in the HR application, Locking a filing cabinet to protect paper records, printed employment contracts that are in files in the filing system, photos and other files stored on your computer, Securing a meeting room to prevent eavesdropping on discussions

Cybersecurity is a *subset* of information security that specifically focuses on protecting data and information systems in *digital or electronic form* from threats such as unauthorized access, cyberattacks, or data breaches.

Ex: Installing antivirus, firewalls, or encryption to protect digital records, Setting up multi-factor authentication (MFA) for logins, Applying software patches to fix vulnerabilities.



Differences between Information Security & Cybersecurity

Aspect	Information Security	Cybersecurity
Scope	Protects all types of information (digital, physical, verbal, printed, etc.)	Protects digital/electronic information stored or transmitted via computers, networks, or the internet
Focus	Ensuring confidentiality, integrity, and availability (CIA) of information in any form	Preventing cyberattacks, data breaches, malware, hacking
Examples	◆ Locking a filing cabinet ◆ Shredding documents ◆ Restricting physical access to server rooms ◆ Guarding confidential discussions	◆ Installing firewalls ◆ Using antivirus software ◆ Encrypting files/emails ◆ Multi-factor authentication
Threats Handled	Theft of paper files, unauthorized entry, social engineering, insider misuse	Hacking, phishing, ransomware, DDoS attacks, malware
Methods Used	Physical security, administrative policies, training employees	Technical controls (encryption, firewalls, intrusion detection, security patches)
Relation	Broad umbrella – covers all forms of information	Subset – only deals with digital/electronic data

Question

- Cybersecurity is a subset of Information Security? Justify
- All cybersecurity is information security. But not all information security is cybersecurity. Justify

All cybersecurity is information security. But not all information security is cybersecurity. Justify

Cybersecurity is information security (subset):

A company sets up a firewall, antivirus software, and strong password policies to protect its online systems from hackers.

→ This is **cybersecurity**, and because it protects information, it is also **information security**.

Information security that is not cybersecurity:

An employee writes down confidential client passwords on paper and leaves them in an unlocked drawer.

→ This is a **violation of information security** (protecting sensitive information) but **not cybersecurity**, because no digital system or network is directly involved.

Cybersecurity Is a Constantly Moving Target

The challenges, threats, and solutions in cybersecurity are always changing, so protecting digital information is never static or fully finished

- Cyber threats evolve continuously- hackers develop new attack methods, malware, and exploits.
- Defensive measures—like software, policies, and best practices—must also evolve to stay effective.
- What worked to secure systems years ago may no longer be adequate today.
 - In the early 2000s, antivirus software that scanned files for known virus signatures was enough to protect most computers.
 - Today, cybercriminals use advanced techniques like zero-day exploits, ransomware, and phishing attacks that can bypass traditional signature-based antivirus.
 - As a result, companies must now use multi-layered defenses—including behavioral detection, threat intelligence, and AI-driven monitoring—to stay protected.

It's like trying to hit a target that keeps moving: you can aim and strike at one point, but the target will have shifted by the time you act, so **you must adapt constantly.**

Cybersecurity Is a Constantly Moving Target

Several key development areas and their impacts on the ever-evolving nature of cybersecurity:

- Technological changes
- Social shifts
- Economic model shifts
- Political shifts

Cybersecurity Is a Constantly Moving Target

Technological changes

Technological advancements (including digital storage, the Internet, mobile devices, IoT, and big data) have dramatically reshaped cybersecurity, introducing both new opportunities and new risks.

As technology evolves, so do the threats, making cybersecurity a constantly moving target. **Key areas of impact include:**

- Digital Data and Its Impact on Cybersecurity
- The Internet
- Cryptocurrency
- Mobile Workforces and Ubiquitous Access
- Smart Devices and IoT
- Big Data

Cybersecurity Is a Constantly Moving Target

Technological changes

Digital Data and Its Impact on Cybersecurity

Past Data Protection

Data protection was simple —physical files stored in locked cabinets, accessed only by authorized personnel during business hours. Additional security included locked offices and alarmed buildings.

Modern Data Protection

Today, information is mostly **digitally stored**, requiring complex systems that can:

- Authenticate users remotely at any time.
- Verify whether users are authorized to access specific data.
- Securely deliver the requested data.
- Protect both the system and data in transit from attacks.

Consequences: The shift to digital email, chat, photography, and videography has increased exposure to theft, ransomware, and piracy. Criminals can now steal, leak, or hold data for ransom, or illegally distribute copyrighted media.

Cybersecurity Is a Constantly Moving Target

Technological changes

The Internet

- The Internet has transformed cybersecurity: hackers can now operate globally, disrupt businesses, manipulate elections, and steal money.
- Before the Internet, hacking rarely offered direct financial gain (impossible to steal large money). Online banking and e-commerce made cybercrime profitable, incentivizing more criminals to enter the field.

Cryptocurrency

- Cryptocurrency has made cybercrime both more profitable and harder to trace, raising the stakes for cybersecurity worldwide.
- Cryptocurrency allows cybercriminals to receive payments anonymously (Ransomware attackers), increasing both their potential profits and their ability to hide illicit activities (Wallets and exchanges can be hacked if not properly secured).
- This removes traditional risks associated with tracing payments, making cybercrime even more attractive.

Cybersecurity Is a Constantly Moving Target

Technological changes

Mobile Workforces and Ubiquitous Access

- Remote access and connectivity, from early services like Outlook Web Access, pcAnywhere, to modern VPNs, have enabled employees to work from anywhere and to securely access corporate systems from anywhere.
- While convenient, this also expands the attack surface, allowing hackers to target corporate systems remotely.

Smart Devices and IoT

- The rise of smart devices and IoT has expanded the range of connected devices beyond traditional computers.
- These devices can be hacked remotely, creating new cybersecurity risks for both personal and organizational networks.

Big Data

Massive volume of structured and unstructured information

Helps cybersecurity: It can be used to detect threats (unusual patterns) and predict attacks.

Risks: Hackers can study this data to find weak points or trick employees (social engineering).

social engineering

Social engineering is a technique where attackers manipulate people into giving away confidential information or performing actions that compromise security.

Attack Type	How It Works	Example
Phishing	Fake emails trick victims into revealing info	“Your bank account will be locked unless you click this link.”
Spear Phishing	Targeted phishing aimed at a specific person or company	Emailing a CEO with a fake invoice to steal money.
Vishing	Phone calls pretending to be from a trusted source	“We detected suspicious activity; please provide your OTP.”
Smishing	Text messages with malicious links or requests	“Click this link to claim your prize.”
Baiting	Tempting victims with free items to infect their system	Leaving a USB labeled “Confidential” that installs malware when used.
Tailgating	Following someone into a secure area without authorization	Pretending to be a delivery person to enter a restricted office.
Impersonation / Pretexting	Pretending to be someone trustworthy to get information	Calling an employee as “IT staff” to get login credentials.

Cybersecurity Is a Constantly Moving Target

Social Shifts

Changes in human behavior and interaction have major effects on cybersecurity:

- The Internet lets people connect worldwide (Global Connectivity), but criminals can also attack from anywhere.
- Moving from paper to online systems (Digital Transformation) means hackers can access data remotely.
- Smartphones and remote access increase opportunities for attacks.
- Social media makes it easy for hackers to gather personal information and trick people (social engineering).

Cybersecurity Is a Constantly Moving Target

Economic model shifts

- The Internet connects almost the entire world, **enabling new business models.**
- Companies now outsource work globally (e.g., call centers in India, software development in the Philippines).
- These global operations introduce new risks, as data and systems must now be protected across borders and multiple locations.
 - Data protection: Information sent to other locations must be safe from theft, tampering, or destruction.
 - Software integrity: Outsourced code could have accidental or intentional back doors.
 - Intellectual property: Companies need extra safeguards to prevent corporate espionage.
 - Indirect attacks: Hackers can target weaker third-party providers instead of the main company to gain access.

Cybersecurity Is a Constantly Moving Target

Political shifts

Governments now have access to advanced technology that can monitor or control information.

Data Collection

- Governments can now spy on their own citizens and people in other countries to collect massive amounts of digital information
- Most business, personal, and social activities leave digital footprints, giving governments access to a huge amount of information.
- Advances in storage, big data, and weakening encryption make it easier and cheaper to store this information.
- Governments are motivated to collect and store as much data as possible for future use.
- If businesses fail to protect their data, hostile nations may access it and use it for short-term or long-term purposes.

Ex: China's Social Credit System

- The Chinese government monitors citizens' online and offline activities.
- Example: Tracking purchases, social media posts, and public behavior to assign scores that affect loans, travel, and jobs.

Cybersecurity Is a Constantly Moving Target

Political shifts

Governments now have access to advanced technology that can monitor or control information.

Election interference

- Governments can spread misinformation easily and cheaply via social media.
- Others can share the false information, increasing reach and impact.
- Electronic voter databases can potentially be hacked from anywhere, creating fears even if actual hacking is unlikely (reduces public trust in elections).
- Online voting could make manipulation even easier in the future.

Example: Some people, including former President Jimmy Carter, expressed doubts about the 2016 U.S. election results, even though investigations found no evidence of fraud.

Cybersecurity Is a Constantly Moving Target

Political shifts

Governments now have access to advanced technology that can monitor or control information.

Hacktivism

Hacktivism is when hackers use their skills to promote a political or social cause.

Hacktivists can target a government or its citizens from anywhere in the world, without being physically present.

Hackers to act against governments or organizations they disagree with.

- Hackers took down websites of governments or corporations to protest policies
- Leaked government or corporate files online - To expose corruption or wrongdoing
- Hackers targeted Iranian government sites - To support freedom of speech and human rights

Greater freedom

- People in repressed countries can see how others live, pushing some governments to liberalize.
- Other governments respond by implementing cybersecurity-type controls to prevent using various Internet based services.

Cybersecurity Is a Constantly Moving Target

Political shifts

Governments now have access to advanced technology that can monitor or control information.

Sanctions

- Sanctions are punishments from one country to another.
- Some countries, like North Korea, use hacking and cryptocurrency to get around these punishments.
- Even people with weak computer security can accidentally help them.

Creating a new balance of power

- In the physical world, powerful countries have stronger armies and more weapons than weaker countries. In cyberspace, this changes because cyberattacks are cheap. Even a small or less powerful country can launch many attacks easily, a tremendous imbalance between attackers and defenders that
- Hackers can attack repeatedly until they succeed, while defenders must stop every single attack to stay safe. This makes defending much harder than attacking.
- Cyberattacks often go unnoticed or unpunished. Victims may not even know they were hacked, and attackers can hide their identity.
- Even superpowers can be breached by smaller nations or groups because a single successful attack is enough. Cybercrime is attractive to criminals: low cost, high chance of success, and minimal risk of getting caught.

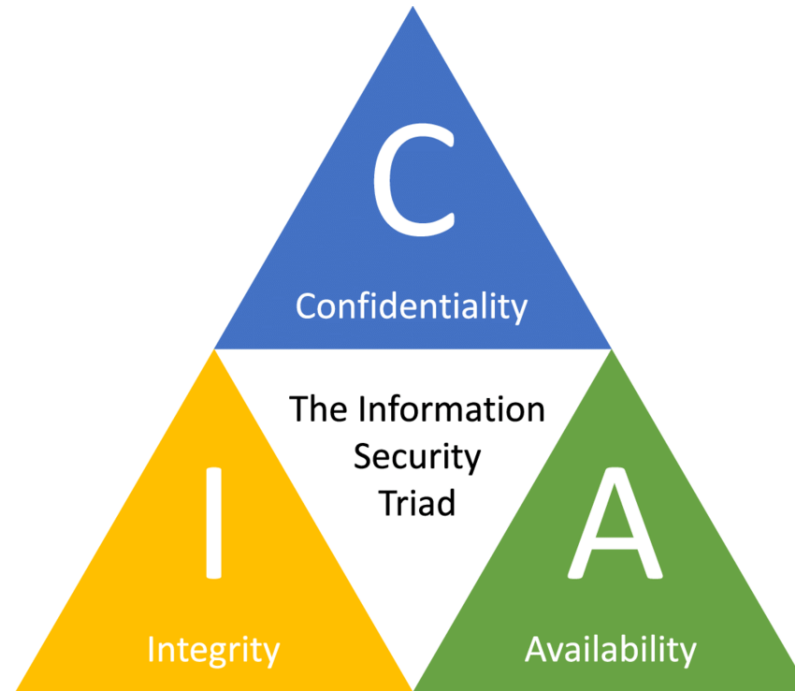
Looking at the Risks That Cybersecurity Mitigates

The goal of cybersecurity: The CIA triad

The goal of cybersecurity is to ensure the Confidentiality, Integrity, and Availability (CIA) of data

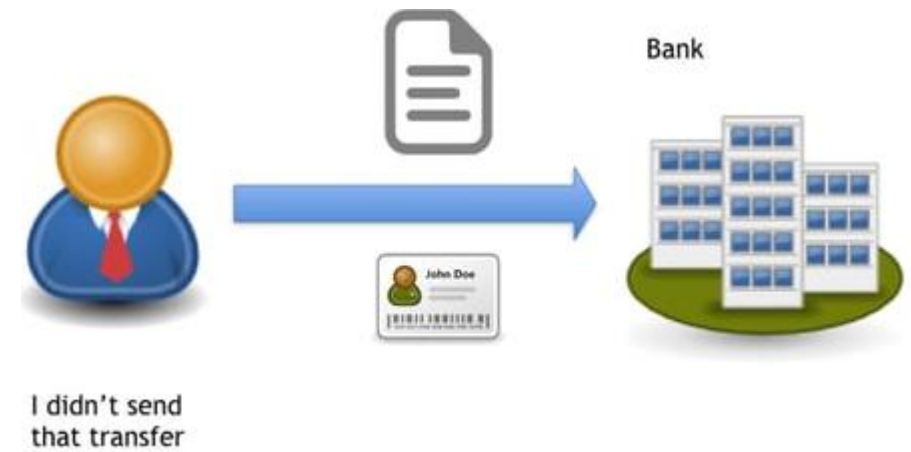
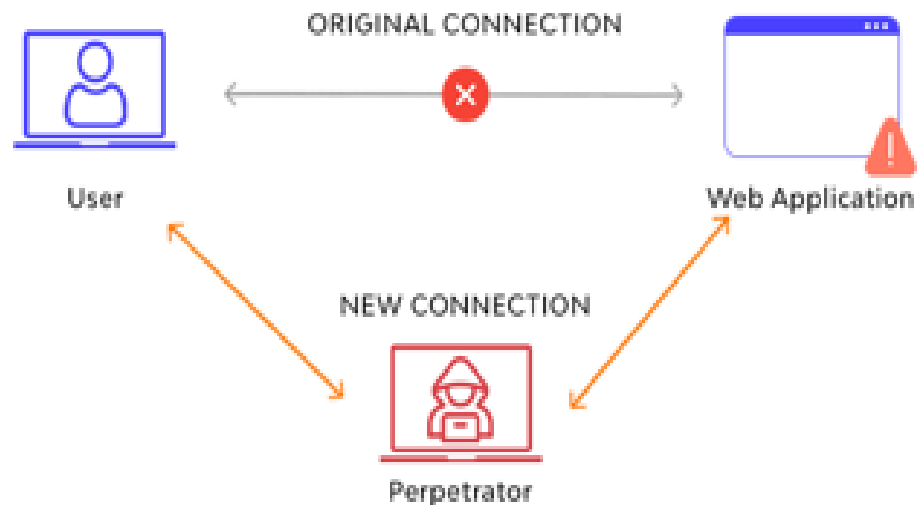
- **Confidentiality**: protecting information from **disclosure** to unauthorized parties
- **Integrity**: protecting information from **modification** by unauthorized parties. To ensure data is both accurate and complete.
 - **Nonrepudiation**: A guarantee that someone cannot deny having performed an action, such as sending an email, signing a document, or making a transaction.
 - **man-in-the-middle attack**: Cyberattacks that intercept data and modify it before relaying it to its destination
- **Availability**: ensuring that authorized parties are able to **access** the information when needed.
 - Distributed denial-of-service attacks attempt to undermine availability
 - Multiple computers overwhelm a website or online service with traffic, making it slow or completely unavailable to users.

Looking at the Risks That Cybersecurity Mitigates



Principle	Example
Confidentiality	Your online banking password is encrypted so only you and the bank can see it.
Integrity	A digital document with a digital signature ensures it hasn't been altered.
Availability	A website has backup servers so it stays online even if one server fails.

Guess the attacks!



Cybersecurity Risks from a Human Perspective

- Cybersecurity isn't just about data and systems, but about real human consequences
- Instead of only looking at cybersecurity risks in technical/organizational terms, we can also frame them from a human perspective, i.e., how people personally experience the consequences of breaches.

Cybersecurity Risks from a Human Perspective

Risk Type	Human-Centered Meaning	Example (Human Impact)
Privacy Risks	Risks from losing control over personal or confidential information. → feeling of being exposed or surveilled.	Medical history, personal photos, or browsing habits are leaked online, pps tracking your location all the time. A person's health records leaked online → embarrassment, loss of dignity.
Financial Risks	Risks of Direct or indirect loss of money → stress, insecurity.	Bank account hacked → money stolen; small shop loses customers after breach.
Professional Risks	Risk of Career or reputation damage → job loss, lawsuits, humiliation.	executive is fired after negligence in a data breach; employee embarrassed by leaked disciplinary record.
Business Risks	Risk of Trust and reputation damage to the organization → loss of livelihood for employees.	Sony Pictures hack → employees and business both affected by leaked compensation data.
Personal Risks	Emotional or relationship harm due to exposure of sensitive/private data.	Leaked private photos ruin personal relationships; identity theft creates social/legal problems.



Sony has agreed to pay up to \$8m over employees' personal data lost in the 2014 hacking scandal surrounding the release of The Interview.



application security # devsecops # hybrid & remote work

40% of businesses sacked staff due to breach of security during COVID-19

Thu, 20th Aug 2020

FYI, this story is more than a year old

Getting to Know Common Cyberattacks

Getting to Know Common Cyberattacks

Exploring attacks that can inflict damage:

- Denial-of-service (DoS) attacks
- Distributed denial-of-service (DDoS) attacks
- Botnets and zombies
- Data destruction attacks

Denial-of-service (DoS) attacks

- A DoS attack occurs when an attacker deliberately attempts **to make a computer, server, or network unavailable** to legitimate users by overwhelming it with excessive traffic or requests.

Ex: A small website is flooded with millions of page requests in a few seconds, causing it to crash and become unavailable to legitimate users.

Targeted Resources:

- CPU & Memory → overwhelmed, slowing down or crashing systems.
- Network Bandwidth → saturated, blocking genuine traffic.
- Networking Infrastructure (e.g., routers, firewalls) → exhausted and unable to route normal traffic.

Types of Requests Used:

- Legitimate-looking requests: e.g., repeated webpage requests that are normally harmless.
- Malformed/protocol-based requests: Attacker uses weaknesses in network protocols (TCP, ICMP, DNS, etc.) to make each request more damaging. Sometimes the requests are malformed (not normal) or use amplification techniques to multiply the traffic.

Protocol-Based / Malformed Requests

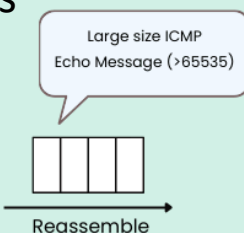
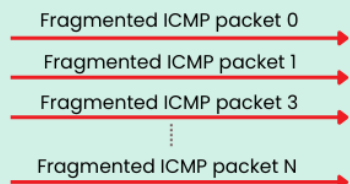
How Does a Ping of Death Attack Work?

an ICMP packet is 64 bytes, but it can be as large as 65,535 bytes

INDUSFACE™

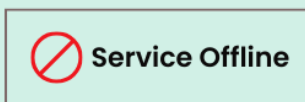


Attacker



Buffer Overflow

The reassembled packet exceeds the buffer allocated by the system for handling such packets.



Copyright © Indusface, All rights reserved.

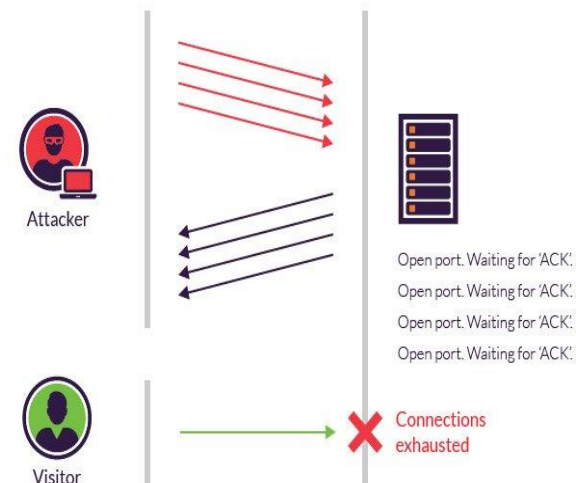
indusface.com

The target system, unable to handle the oversized packet, may crash, freeze, or restart.

Ping of Death (ICMP)

Client IP: 192.0.2.10
DNS Server IP: 8.8.8.8
Query: www.example.com A
Size: ~60 bytes

SYN Flood (TCP)



DNS amplification

Server IP: 8.8.8.8
Client IP: 192.0.2.10
Answer: 93.184.216.34
Size: ~512 bytes (or larger if DNSSEC is used)

Distributed denial-of-service (DDoS) attacks

- Unlike a standard DoS attack, which typically comes from a single machine, a DDoS attack leverages many devices (computers, IoT devices, cameras) from different locations. These devices are often part of a botnet, controlled remotely by the attacker.

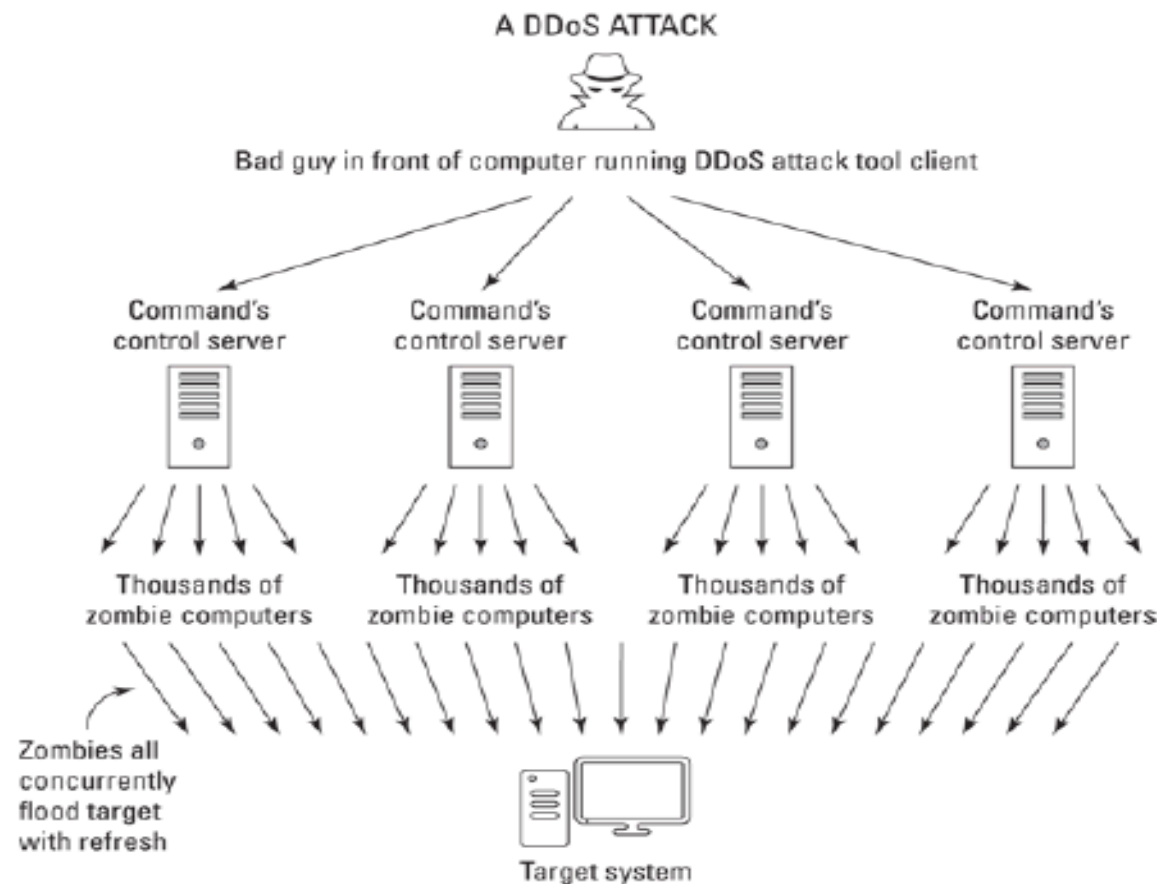


FIGURE 2-1: A DDoS attack.

DDoS Attacks: Goals and Motivations

- Primary Goal: Knock the victim's system or website offline.

Financial Motives:

- Disrupt an online retailer during peak sales events (e.g., Black Friday) to cause financial loss.
- Manipulate stock prices (e.g., short a company's stock, then launch a DDoS attack before high-demand periods like Christmas). DDoS-for-hire services are offered on the dark web, allowing attackers to take competitors offline for a fee.

Political Motives

- Corrupt politicians may disrupt opponents' websites during elections to limit campaign outreach and contributions.
- Hacktivists may target organizations or government sites in the name of "justice" (e.g., after controversial incidents involving law enforcement).

DDoS Attacks: Goals and Motivations

According to a 2017 study by Kaspersky Lab and B2B International, nearly half of companies worldwide that experienced a DDoS attack suspected competitor involvement.

Impact on Individuals: DDoS attacks affect users in several ways:

Slowing Local Network Access:

- Attacks on a local network can significantly slow down Internet connectivity.
- Connections may fail due to session timeouts, where systems terminate requests that take too long to respond.

Making Websites Inaccessible:

Individuals may be unable to access sites they plan to use.

Example: On October 21, 2016, a massive DDoS attack against a third-party service disrupted access to Twitter, PayPal, CNN, HBO Now, The Guardian, and many other sites.

Impacting Online Transactions:

DDoS attacks can prevent users from performing time-sensitive tasks, such as online banking, which is why users should avoid waiting until the last minute.

Influencing Information Access:

Making a site unavailable can redirect users to alternative sources for information.

This can be exploited to: Spread misinformation. Suppress opposing viewpoints or critical information. DDoS attacks can act as a short-term censorship tool, limiting access to certain perspectives.

Botnets and zombies

Botnets

- A botnet is a collection of compromised computers (belonging to unsuspecting users) that a hacker remotely controls without the owners' knowledge.

Zombies: Each infected computer in a botnet is called a zombie.

- Zombies can be commanded to perform tasks, such as sending requests to a server, without the user being aware.
- Attack Mechanism: Criminals can infect millions of computers with malware. These zombie machines can simultaneously flood a target server or server farm with traffic, overwhelming it and causing a DDoS attack.

Data destruction attacks

Unlike standard DDoS attacks that aim to temporarily take a system offline, data destruction attacks target a victim's information or information systems with the **intent to damage or destroy data**.

- Criminals may launch such attacks for financial gain, such as forcing a user to pay a ransomware demand.
- All other motivations for DDoS attacks—political, hacktivist, or competitive reasons—can also apply to data destruction attacks.

Wiper Attacks: Wipers are advanced data destruction attacks that use malware to erase data on hard drives or SSDs. The erased data is often difficult or impossible to recover without backups.

- Impact: Victims lose access to all data and software stored on the affected device if no backups exist, resulting in potentially severe personal or organizational damage.

Feature	DDoS Attack	Data Destruction Attack
Primary Goal	Make a system or website temporarily unavailable by overwhelming it with traffic.	Damage or destroy data and/or the information system itself.
Effect on Target	Slows down or blocks access to services, but usually does not corrupt data.	Causes loss or corruption of data, potentially making it irrecoverable.
Duration of Impact	Usually temporary, until the traffic stops or mitigation occurs.	Can be permanent, especially if backups are not available.
Common Methods	Botnets, flooding servers with traffic, application-layer attacks.	Malware, ransomware, wiper programs that erase hard drives or SSDs.
Typical Motivation	Financial (competitor sabotage), political (censorship), hacktivist activism.	Financial (ransom), revenge, sabotage, or hiding evidence.
User Experience	Websites may be slow or inaccessible; online services disrupted.	Users may lose all data and software, making systems unusable.

Impersonation

- An impersonation attack (also called spoofing) is a type of cyberattack in which a malicious actor pretends to be someone or something else to deceive users and gain access to sensitive information, money, or resources.

Creating Fake Websites:

- Criminals can quickly set up a website that mimics a legitimate site, sometimes within minutes.
- They often use domain names similar to real ones to trick users into believing the site is authentic.

Consequences: Users may be deceived into providing sensitive information, such as login credentials, personal data, or money.

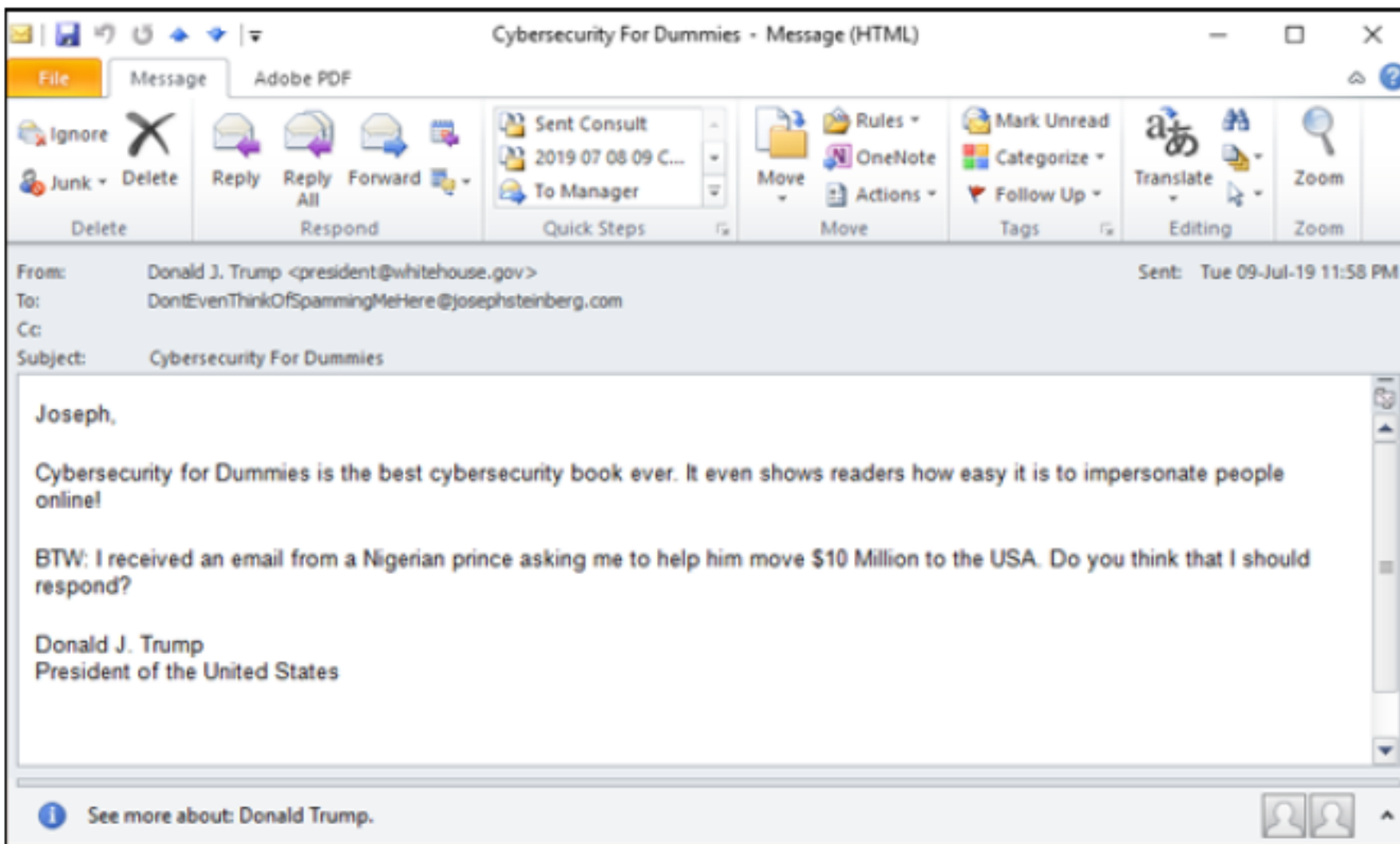


FIGURE 2-2: An impersonation message.

Figure 2-2 shows another email message that may have been faked.

Phishing

- Phishing is a social engineering attack where attackers pretend to be someone trustworthy (like a bank, government agency, or well-known company) to trick people into giving away sensitive information such as usernames, passwords, or financial details.
- Eg: “Your account has been locked due to suspicious activity. Please click here to verify your account.”

How to prevent

- Verify sender’s email address carefully.
- Hover over links before clicking to check if the URL is genuine.
- Use multi-factor authentication (MFA).
- Never provide personal details through unsolicited emails.
- Report suspicious messages to IT/security teams or the bank directly.

Spear phishing

- Spear phishing refers to phishing attacks that are designed and sent to target a specific person, business, or organization.
- For example, the following type of email is typically a lot more convincing than “Please login to the mail server and reset your password.”:

“Hi, I am going to be getting on my flight in ten minutes. Can you please login to the Exchange server and check when my meeting is? For some reason, I cannot get in. You can try to call me by phone first for security reasons, but, if you miss me, just go ahead, check the information, and email it to me — as you know that I am getting on a flight that is about to take off.”

- pretends to be a **colleague traveling on a flight**.
- Creates **urgency** (“I’m boarding in 10 minutes”).
- Adds a **trust element** (“try to call me first for security reasons”).

How to prevent

- Awareness training for employees.
- Multi-factor authentication (MFA) so stolen passwords alone aren’t enough.
- Verify requests (e.g., call back using a known number, not the one in the email).
- Restrict oversharing on social media (travel plans, job details, email formats).

Spear phishing *CEO fraud*

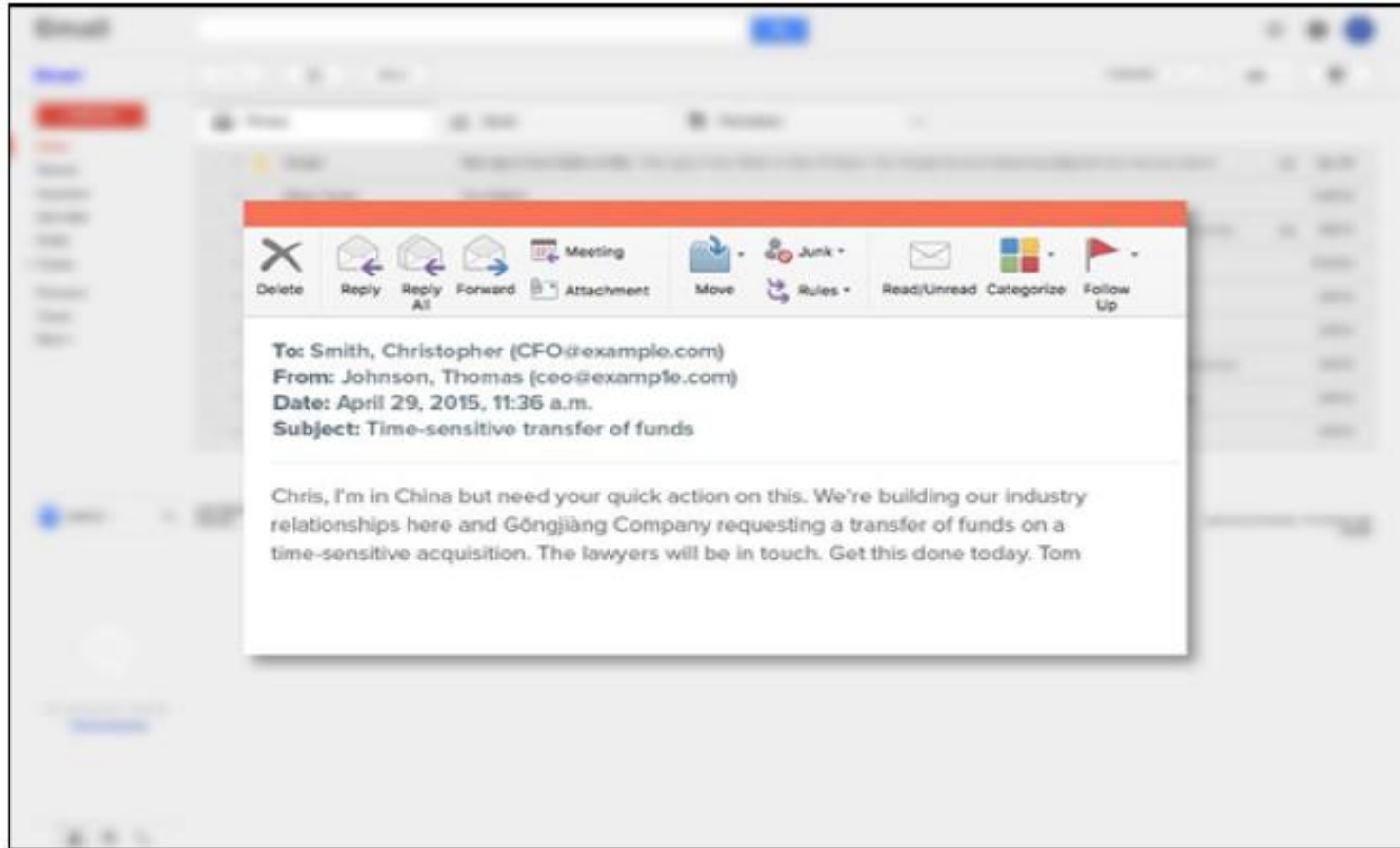


FIGURE 2-3: A fraudulent email.

Smishing

- Smishing is a type of phishing attack where attackers use **SMS (text messages)** instead of email to trick victims.
 - Steal **credentials** (usernames, passwords, banking PINs).
 - Convince victims to **click a malicious link**.
 - Trick victims into **installing malware** on their phones.

How to prevent

- Never click on suspicious links in SMS messages.
- Verify messages by contacting the bank or company directly.
- Use mobile security apps to detect malicious links.

Vishing

- *Vishing*, or voice-based phishing, is phishing via POTS — that stands for “plain old telephone service.”
- Attackers call the victim pretending to be from a bank, government agency, tech support, or company helpdesk.

“Hello, this is the fraud department from your bank. We detected suspicious charges on your debit card. Please confirm your card number, CVV, and the OTP sent to your phone so we can block the transaction.”

How to prevent

- Never share sensitive details (PIN, OTP, card number) over the phone.
- Banks, government agencies, and tech companies will never ask for credentials on calls.
- Hang up and call back using an official, verified number.

Whaling

- Whaling is a special type of spear phishing attack that specifically targets high-profile individuals, such as CEOs, CFOs, government officials, or other executives.
- *An email that looks like it's from the CEO to the CFO: "We're finalizing a confidential acquisition deal. Please wire \$5 million to the following account immediately. I'll be in meetings all day, so handle this discreetly."*

How to Prevent

- Educate executives and senior staff about phishing risks.
- Use multi-step approval for sensitive transactions.
- Enable email authentication methods

Tampering

- Tampering is when attackers illegally alter data, either in transit (while being sent) or at rest (stored in systems), in order to cause harm or gain financial/other benefits.

Data in Transit:

- Example: A user initiates an online banking transaction to send money to a supplier.
- An attacker intercepts the request and modifies the destination account number so the funds go to the attacker's account.

Data at Rest (Stored Data):

- Example: An attacker hacks into a company's payment system.
- They change the stored payment address of a vendor so that all future payments go to the attacker's account.

How to Prevent

- Encryption: Protects data in transit from being intercepted and altered.
- Digital Signatures & Checksums: Detect unauthorized changes.
- Access Controls: Limit who can modify data in systems.
- Audit Logs: Help detect suspicious modifications.

Interception

- Interception occurs when attackers **capture data while it is in transit** between two systems (e.g., between a user's browser and a bank's server).
- If the data is not encrypted, attackers can directly read and misuse sensitive information (like usernames, passwords, account numbers).

Man-in-the-Middle (MITM) Attack

- A special type of interception where the attacker secretly proxies (sits in between) the communication between the sender and receiver.

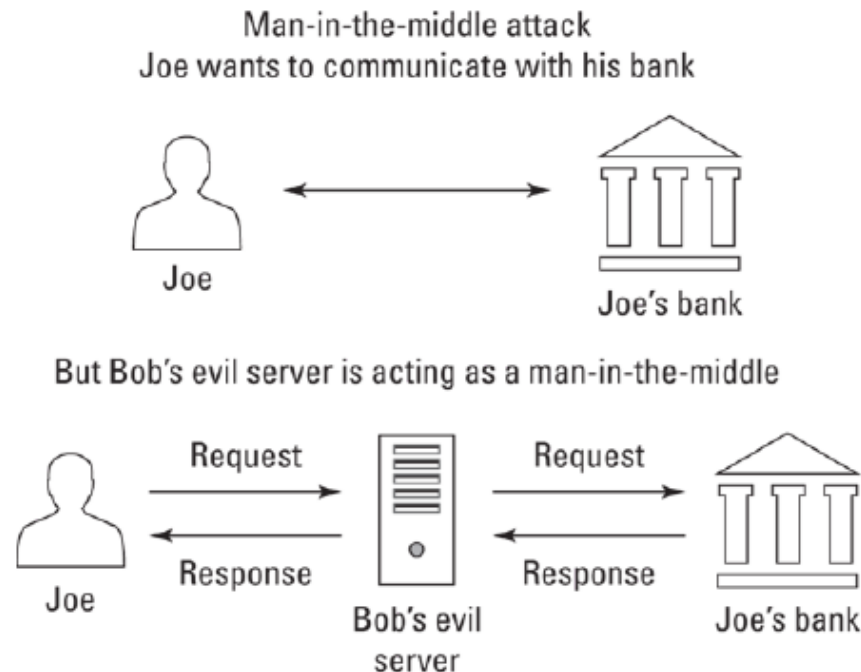


FIGURE 2-4: A man-in-the-middle interception.

Data Theft

- Data theft occurs when criminals steal sensitive information from individuals, businesses, or governments for financial gain, blackmail, competitive advantage, or disruption.

Personal Data Theft

Attackers steal individuals' information to exploit or sell. Examples:

- **Identity Theft:** Personal details used to impersonate the victim and sell to identity thieves (Name, date of birth, Social Security number (or Aadhaar/PAN in India), driver's license, etc.).
- **Blackmail Material:** Compromising Private photos or health data used for blackmail/extortion.
- **Ransomware:** Data stolen, delete/encrypt files and demand ransom to restore access.
- **Password Lists:** Saved login credentials (from browsers, keyloggers, breaches) and used to hack into multiple accounts.
- **Insider Trading:** Work-related confidential info used for illegal stock trades.
- **Travel Plans:** Used to plan robberies when the victim is away based on upcoming travel plans.

Data Theft

Business Data Theft

- Attackers target companies for financial or competitive advantage.

Examples:

- **Insider Trading:** Advance financial results used to profit from stock trades (advance knowledge of how a quarter is going to turn out).
- **Selling Data to Competitors:** Sales pipeline, product designs, or strategic plans sold to rivals.
- **Leaking to Media:** Embarrasses the company, damages reputation, and affects stock prices (Ex: Sony Pictures Hack (2014): Hackers leaked sensitive emails, unreleased movies, and employee data.)
- **Privacy Regulation Violations:** Stolen customer data (like health or financial info) can trigger fines (Ex: If a hospital's patient database is breached, regulators may fine them for not protecting sensitive health info)
- **Recruitment Exploitation:** Using stolen emails to find unhappy employees and poach them. Selling the information to other firms looking to hire employees with similar skills or with knowledge of competitors' systems.
- **Intellectual Property (IP) Theft:** Source code, R&D documents, or product designs stolen — saving criminals or competitors millions/billions in costs.

HOW A CYBERBREACH COST ONE COMPANY \$1 BILLION WITHOUT 1 CENT BEING STOLEN

Theft of intellectual property (IP), such as confidential design documents and computer source code, is an extremely serious matter and a growing area of cybercrime.

For example, in 2007, the Massachusetts-based technology firm American Superconductor, which manufactured software to control wind turbines, partnered with Sinovel, a Chinese firm that manufactured wind turbines, to start selling the turbines in China.

In 2011, Sinovel suddenly refused to pay American Superconductor \$70 million that it owed the firm and began to sell turbines with its own software. An investigation revealed that Sinovel had illegally obtained the IP of American Superconductor by bribing a single employee at the American firm to help it steal the source code.

American Superconductor nearly went bankrupt as a result, declined in value by more than \$1 billion, and had to let go of 700 employees, nearly half of its workforce.

Malware

- Malware (short for malicious software) is any software that is created to harm the computer, steal the information, or misuse the device without your knowledge.
- Malware includes computer viruses, worms, Trojans, ransomware, scareware, spyware, cryptocurrency miners, adware, and other programs intended to exploit computer resources for nefarious purposes.

Malware

- **Virus** – attaches to files and spreads when you share them.
- **Worm** – spreads on its own through networks.
- **Trojan** – looks like a safe program but secretly causes harm.
- **Ransomware** – locks your files and demands money.
- **Spyware** – secretly watches what you do and steals data.
- **Adware** – shows unwanted ads.
- **Crypto miners** – secretly use your computer to generate digital money.

Viruses

- Computer viruses are a type of malware that replicate by attaching their code into files, boot sectors, or programs.
- They usually need a host (like a file or program) to spread — unlike worms, which can spread on their own
- They usually hide in: Files (like fake macros in Word documents), Boot sectors (the part of a drive that starts the computer), or Other computer programs.
- Viruses can range from highly disruptive (slowing down or damaging systems) to almost invisible in their impact.

Worms

- **Worms** are independent malware (unlike viruses, they don't need a host file or program).
- They spread on their own, usually by **exploiting security flaws** in systems and networks.
- Even if they don't steal data or damage files, they still cause harm by **using up bandwidth** and slowing down computers and networks.

Ex:

- **I Love You** (2000) spread rapidly via email and clogged mail servers worldwide, causing billions in damages
- [Stuxnet](#) was probably developed by the US and Israeli intelligence forces with the intent of setting back Iran's nuclear program.

Trojans

- Trojans (appropriately named after the historical Trojan horse) is malware that is either disguised as nonmalicious software or hidden within a legitimate, nonmalicious application or piece of digital data.
- Trojans are most often spread by some form of social engineering — for example, by tricking people into clicking on a link, installing an app, or running some email attachment.
- Unlike viruses (need a host) and worms (spread automatically), Trojans do not self-replicate. They rely on human mistakes to spread.

Ex: A fake “free antivirus app” that secretly installs spyware is a Trojan.

Ransomware

- Malware that demands money (a ransom) from victims to avoid harm.
- Encryption-based ransomware: locks/encrypts your files, and the attacker threatens to delete the decryption key if ransom isn't paid.
- Data-theft ransomware: steals files and threatens to leak/publish them if ransom isn't paid.
- Often comes as a Trojan (hidden in a fake app/attachment) or a virus. Sometimes spreads as a worm, moving automatically across networks.
- Criminals run targeted ransomware attacks- how critical the data is and how much the target can afford (e.g., a hospital, a company)

Ex: WannaCry (2017) – a global ransomware worm that exploited a Windows vulnerability, locking hundreds of thousands of computers worldwide.

Ooops, your important files are encrypted.

If you see this text, then your files are no longer accessible, because they have been encrypted. Perhaps you are busy looking for a way to recover your files, but don't waste your time. Nobody can recover your files without our decryption service.

We guarantee that you can recover all your files safely and easily. All you need to do is submit the payment and purchase the decryption key.

Please follow the instructions:

1. Send \$300 worth of Bitcoin to following address:

1Mz7153HMuxXTuR2R1t78mGSdzaAtNbBWx

2. Send your Bitcoin wallet ID and personal installation key to e-mail wowsmith123456@posteo.net. Your personal installation key:

zRNagE-CDBMfc-pD5Ai4-vFd5d2-14mhs5-d7UCzb-RYjq3E-ANg8rK-49XFX2-Ed2R5A

If you already purchased your key, please enter it below.

Key: _

Ransomware



Scareware

- Malware designed to frighten users into doing something.
- Displays fake warnings or alerts claiming the device is infected.
- Urges the user to buy a specific (often fake or malicious) security product or click a dangerous link.
- Goal: To trick people into paying money or downloading more malware.
- EX: A pop-up that says “Your computer is infected with 5 viruses! Click here to fix now!” → If you click, you might be asked to buy fake antivirus software or unknowingly install more malware.

Spyware

- Software that secretly collects information from a device without the user's permission.
- Spyware may capture a user's keystrokes (in which case it is called a keylogger), video from a video camera, audio from a microphone, screen images, and so on.
- Invasive but not malware (sometimes called legitimate spyware): collects data, but usually with some form of disclosure, such as app permissions or website privacy notices.
 - Beacons → tiny trackers that check if you visited or opened a page/email.
 - Tracking cookies → store browsing behavior for ads.
 - App location tracking → e.g., Uber tracking users' locations even when they're not using the app.
- Malware spyware → no consent, harmful intent.
- Invasive programs → annoying or privacy-invasive, but typically legal because users "accepted" terms or permissions.

Feature	Spyware (Malware)	Invasive Programs (Non-malware that also spies)
Consent	Installed secretly, no user consent	User usually “agrees” via app permissions or terms of service
Intent	Malicious → steals sensitive data (passwords, files, credit card info)	Business/marketing purpose → track usage, show ads, gather analytics
Examples of Data Collected	Keystrokes (keylogger), camera video, microphone audio, screen captures	Web beacons (page/email loads), tracking cookies, app location tracking
Legality	Illegal → violates privacy and security laws	Generally legal (but controversial) if disclosed in privacy policy/permissions
Control	Controlled by hackers or cybercriminals	Controlled by legitimate companies (advertisers, app developers)
User Awareness	User is unaware of installation and spying	User may not read/notice the disclosure, but it exists
Impact	Can cause identity theft, financial fraud, blackmail	Leads to privacy invasion, profiling, targeted ads

Cryptocurrency miners

- Cryptocurrency miners are a type of malware that secretly uses a victim's device processing power to generate cryptocurrency for cybercriminals.

How Cryptominer Malware Works

- Infects computers, mobile devices, or servers without user permission.
- Uses CPU or GPU cycles to perform the calculations required to mine cryptocurrencies.
- Sends the mined rewards to wallets controlled by attackers.

Why Cybercriminals Use Them

- Steady income stream: Even if each device generates tiny profits, mass infections scale up earnings.
- No need for human interaction: Victims may not realize their device is compromised since the attack just slows performance rather than demanding money.
- Resilient over time: Attackers can keep deploying miners with little cost even when crypto values fall.

Cryptocurrency miners

Key Trends

- 2017 boom: Mining malware spread rapidly as cryptocurrency prices rose.
- 2019 resurgence: A new wave of cryptominers appeared alongside price increases, including strains targeting Android smartphones.
- Ongoing presence: Many low-level cybercriminal groups still use miners to quietly profit through large botnet-style operations.

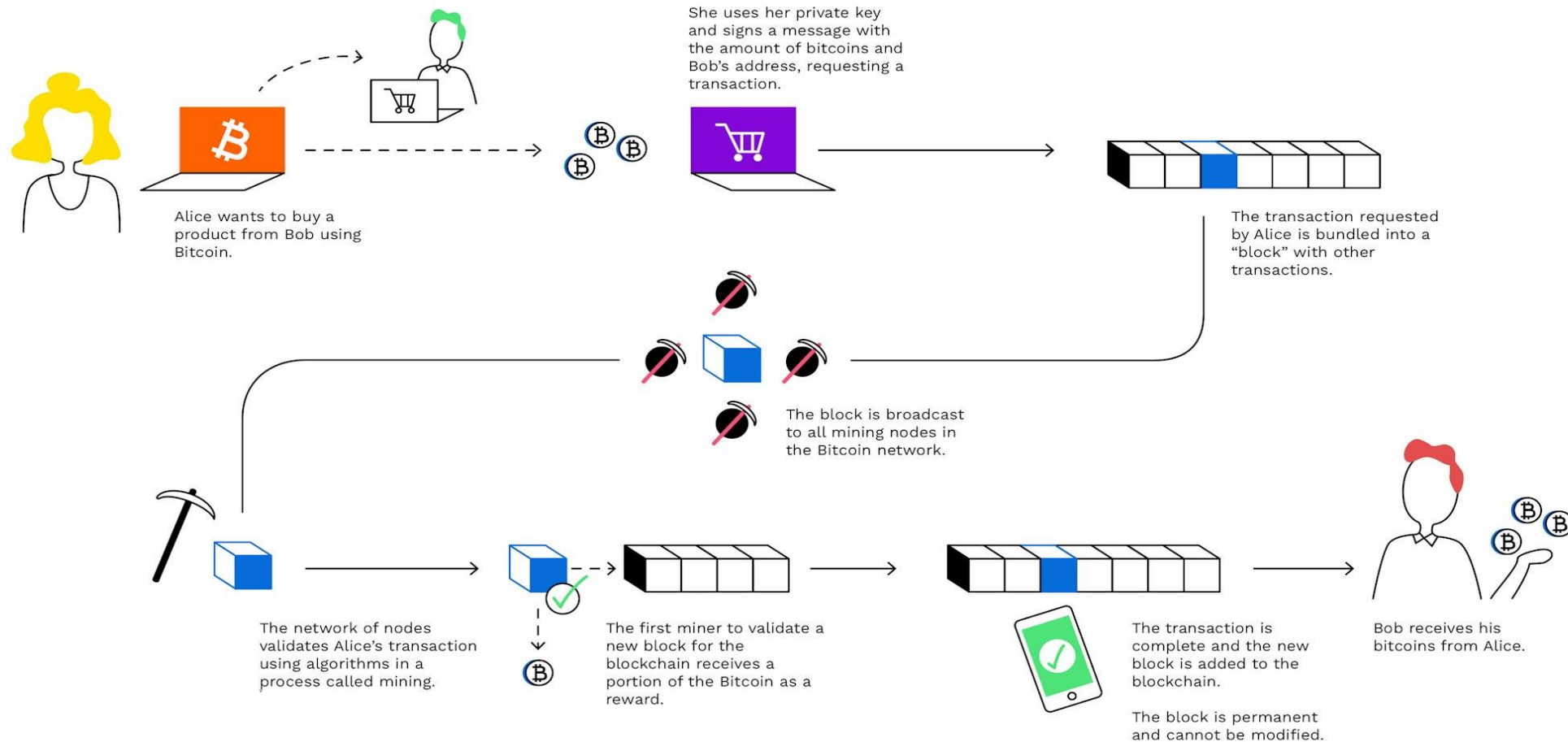
Risks for Victims

- Reduced device performance and overheating.
- Shortened hardware lifespan due to resource overuse.
- Higher electricity bills.
- Potential entry point for additional malware infections.

Cryptocurrency mining is the process by which transactions are validated and new coins are created on a blockchain network like Bitcoin

What is Bitcoin Mining?

How Bitcoin Transactions work



Adware

- Adware is software designed to generate revenue by displaying advertisements, and it can be either legitimate (installed knowingly by users as part of some free, ad-supported package) or malicious (installed without consent, acting as malware).
- Privacy: Malicious adware can harvest browsing habits, personal data, and transfer this information to third parties
- Security: Adware can be a gateway for other threats, including ransomware and spyware.

Blended malware

Blended malware is malware that utilizes multiple types of malware technology as part of an attack — for example, combining features of Trojans, worms, and viruses.

Zero day malware

Zero day malware is malicious software that exploits a previously unknown vulnerability in software or hardware—one that is neither known to the vendor nor the public, making it extremely difficult to detect or defend against.

EX: The EternalBlue exploit used in WannaCry ransomware and Hafnium malware exploiting Microsoft Exchange are famous cases of zero day malware usage

Key Characteristics of Zero Day Malware

- **Unknown vulnerability:** The malware exploits a security flaw that developers are unaware of and for which no patch exists.
- **Exploited before fixes:** Attackers leverage these vulnerabilities immediately or before the vendor can create and distribute patches, leaving a critical window of exposure known as "day zero".
- **High potency and stealth:** Due to the lack of detection signatures and protections, zero day malware can infiltrate and damage systems silently and effectively.
- **Expensive and sophisticated:** Developing zero day exploits requires substantial resources and expertise, often linked to nation-state actors or organized groups; single exploits have reportedly sold for over \$1 million

Poisoned Web Service/web Page Attack

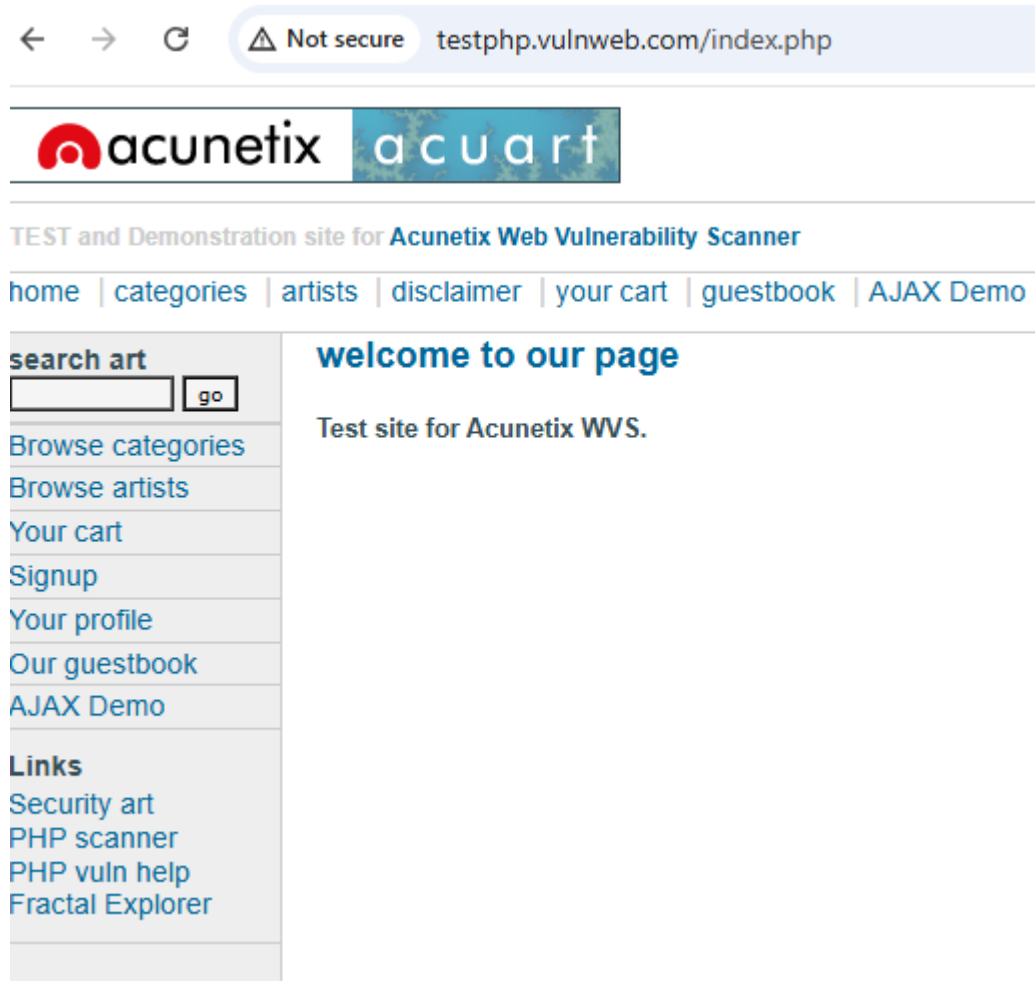
- An attacker compromising a web server or exploiting vulnerabilities in web applications to insert malicious code or commands.
- This poisoned content is then served to users visiting the affected pages, often resulting in malware infections or credential theft.

Poisoned web page attack: Hacker modifies a legitimate web page on a compromised server to include malicious scripts or malware, which execute on users' browsers when they access the page

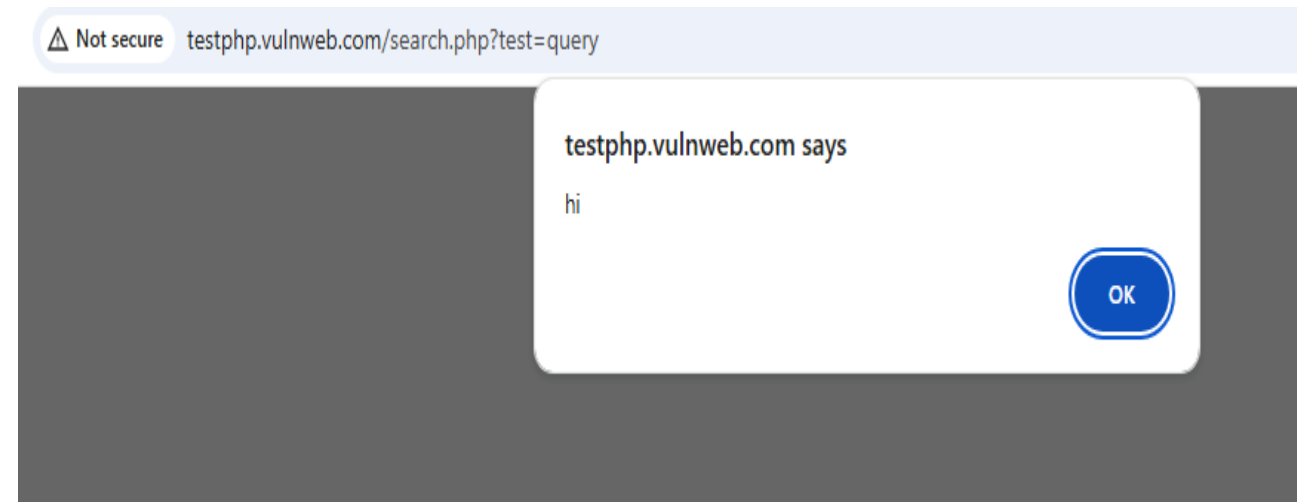
XSS is a web security vulnerability that allows an attacker to inject **malicious scripts (usually JavaScript)** into web pages viewed by other users.

Cross Site Scripting example

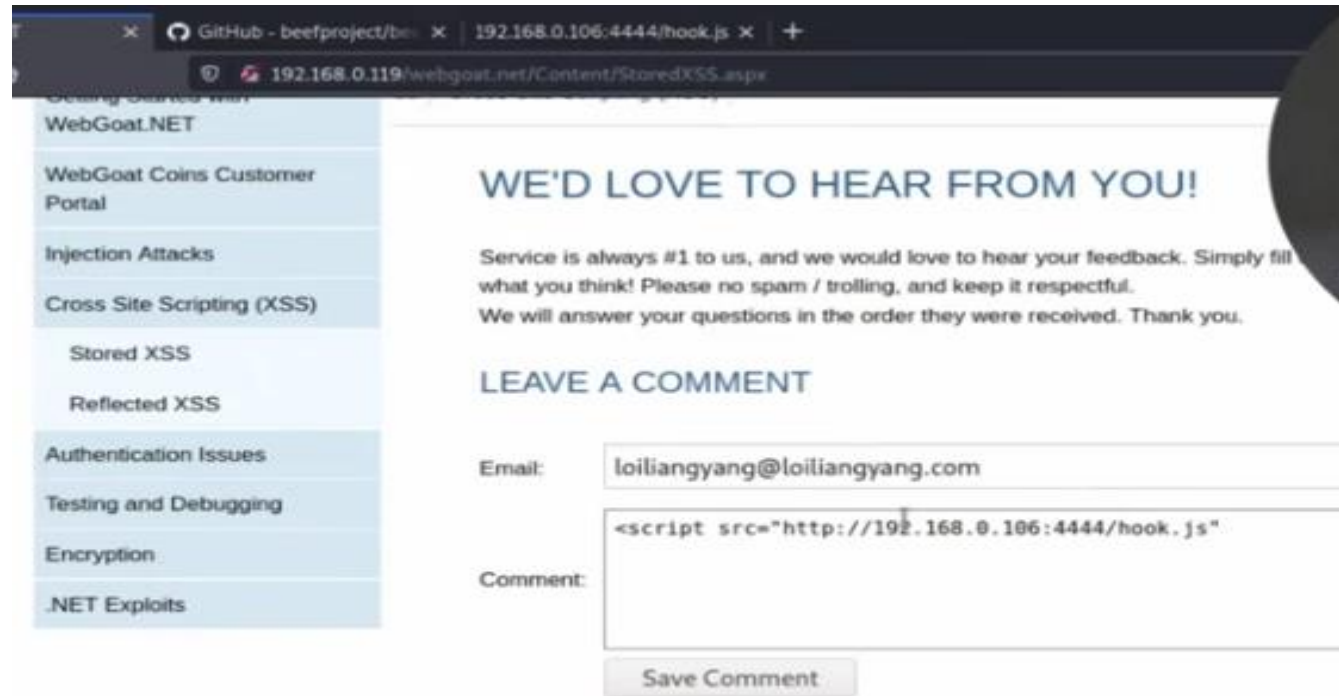
<http://testphp.vulnweb.com/index.php>



```
<script>alert("hi")</script>
```



Cross Site Scripting example

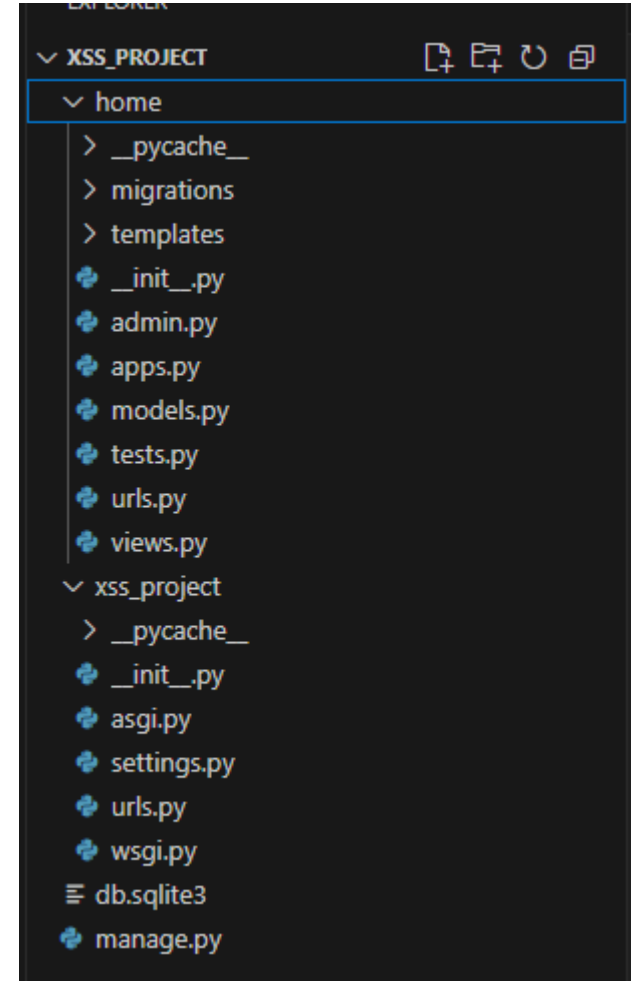


<https://www.youtube.com/watch?v=PPzn4K2ZjfY&t=86s>

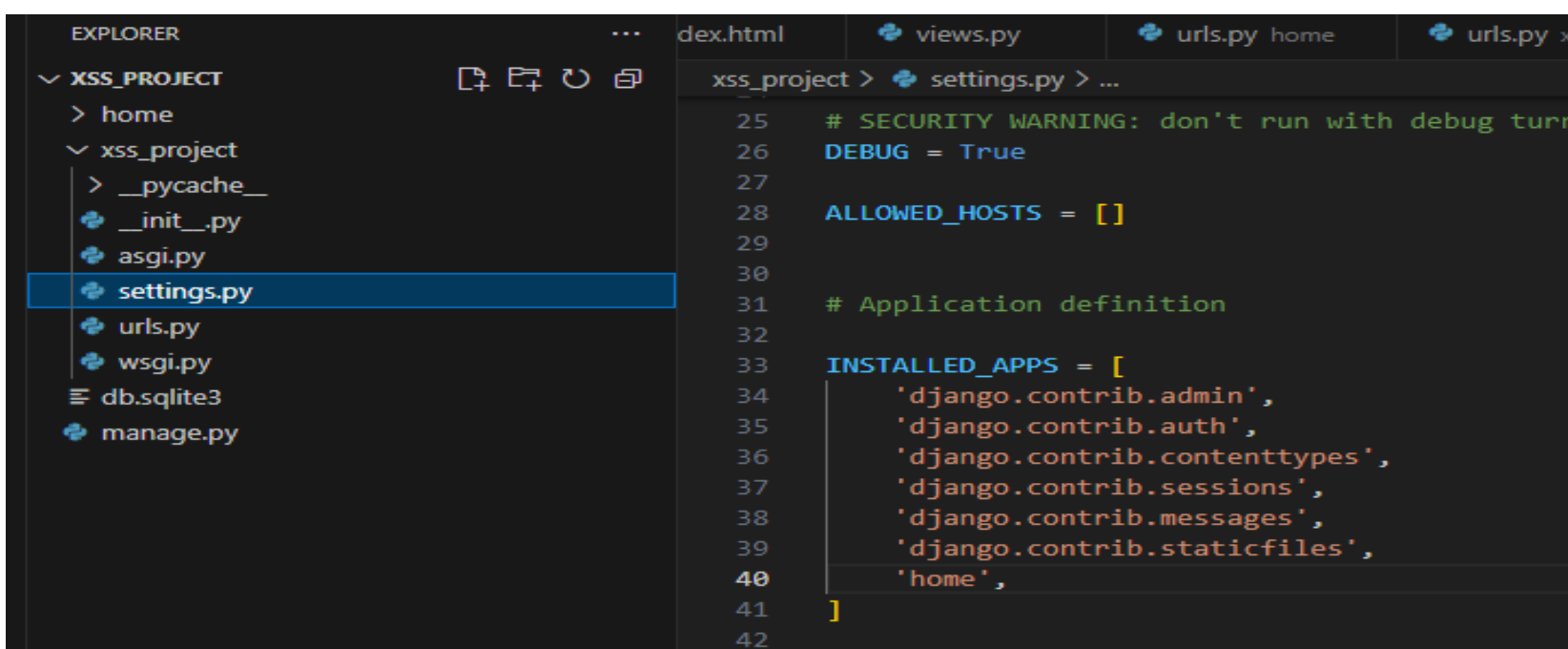
Project: XSS_Project

App: home

- django-admin startproject **XSS_Project**
- cd **XSS_Project**
- python manage.py startapp **home**
- python manage.py runserver
- code .



Create **urls.py** under **app folder: home**

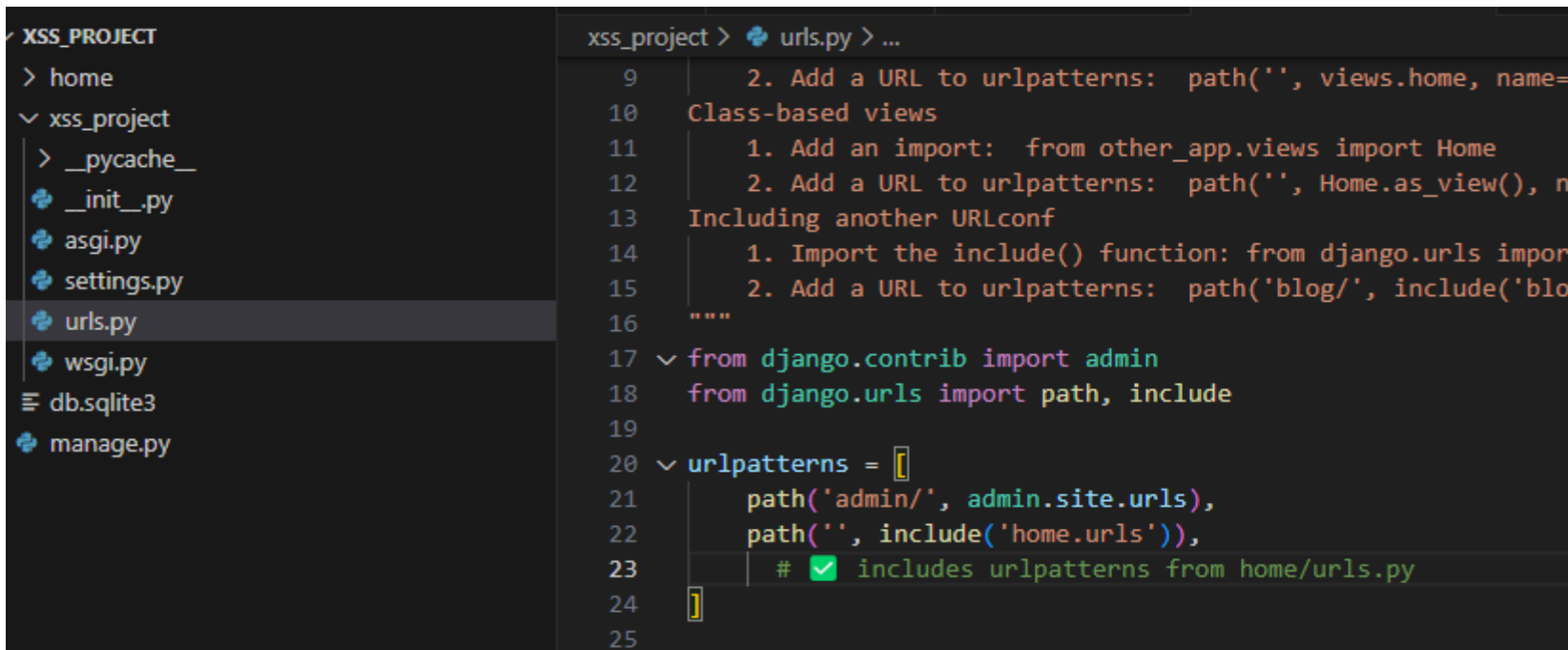


The screenshot shows the VS Code Explorer on the left with the 'xss_project' folder expanded. The 'settings.py' file is selected. The main editor shows the content of 'settings.py' with line numbers 25 to 42. The code includes a security warning, debug mode setting, allowed hosts, and a list of installed apps.

```
25 # SECURITY WARNING: don't run with debug turned on in production
26 DEBUG = True
27
28 ALLOWED_HOSTS = []
29
30
31 # Application definition
32
33 INSTALLED_APPS = [
34     'django.contrib.admin',
35     'django.contrib.auth',
36     'django.contrib.contenttypes',
37     'django.contrib.sessions',
38     'django.contrib.messages',
39     'django.contrib.staticfiles',
40     'home',
41 ]
42
```

project folder xss_project

Under **settings.py** Add the app name 'home'



The screenshot shows the VS Code Explorer on the left with the 'xss_project' folder expanded. The 'urls.py' file is selected. The main editor shows the content of 'urls.py' with line numbers 9 to 25. The code includes instructions for adding URL patterns and includes the necessary imports and urlpatterns definition.

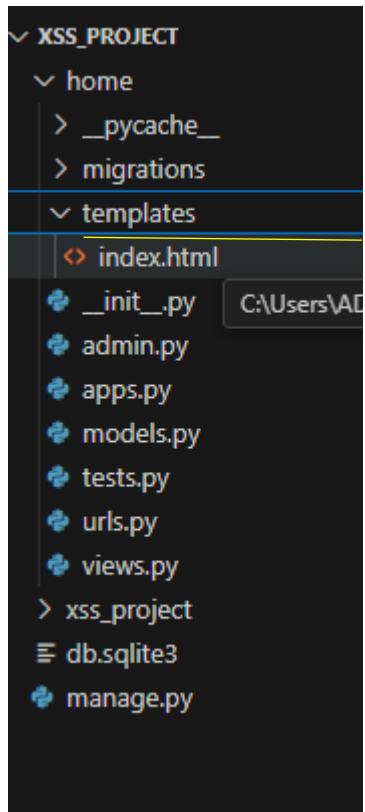
```
9 2. Add a URL to urlpatterns: path('', views.home, name='home')
10 Class-based views
11 1. Add an import: from other_app.views import Home
12 2. Add a URL to urlpatterns: path('', Home.as_view(), name='home')
13 Including another URLconf
14 1. Import the include() function: from django.urls import include
15 2. Add a URL to urlpatterns: path('blog/', include('blog.urls'))
16 """
17 from django.contrib import admin
18 from django.urls import path, include
19
20 urlpatterns = [
21     path('admin/', admin.site.urls),
22     path('', include('home.urls')),
23     # includes urlpatterns from home/urls.py
24 ]
25
```

project folder xss_project

Under **urls.py** include the **urls patterns**

from django.contrib import admin
from django.urls import path, include

```
urlpatterns = [
    path('admin/', admin.site.urls),
    path('', include('home.urls')),
]
```



App folder home:

Create a folder: **templates** and create a html file **index.html**

```
<!DOCTYPE html>
<html>
<head>
  <title>Script Kiddie</title>
</head>
<body>
  <h1>Cross Site Scripting</h1>
  <form method="POST" action="nameRef/">
    {% csrf_token %}
    <label>Name:</label>
    <input type="text" name="name" placeholder="enter your name">
    <input type="submit" value="submit">

  </form>
</body>
</html>
```

The screenshot shows a code editor with a dark theme. On the left is the 'EXPLORER' sidebar showing a project named 'XSS_PROJECT'. Under 'home', there are files like '_pycache_', 'migrations', 'templates', 'index.html', and Python files '_init_.py', 'admin.py', 'apps.py', 'models.py', 'tests.py', 'urls.py', and 'views.py'. The 'views.py' file is selected, and its path is shown as 'C:\Users\ADMIN\XSS_PROJECT\home\views.py'. The main editor area shows the code for 'views.py' with line numbers 1 through 25. The code includes imports for 'render' and 'HttpResponse', and defines two functions: 'index' and 'nameRef'.

```
1 from django.shortcuts import render
2 from django.http import HttpResponse
3
4 def index(request):
5     return render(request, 'index.html')
6
7 def nameRef(request):
8     if request.method == "POST":
9         name = request.POST.get("name")
10        if not name:
11            return HttpResponse("Please enter your name.")
12
13        name1 = name.lower()
14
15        if "script" in name1:
16            # Replace "script" with empty string
17            name2 = name1.replace("script", "")
18            return HttpResponse(name2)
19        else:
20            return HttpResponse(name1)
21    else:
22        return HttpResponse("Please Enter your name.")
23
24
25 # Create your views here.
```

App folder home: **Views.py:**

from django.shortcuts import render

from django.http import HttpResponse

```
def index(request):
    return render(request, 'index.html')
```

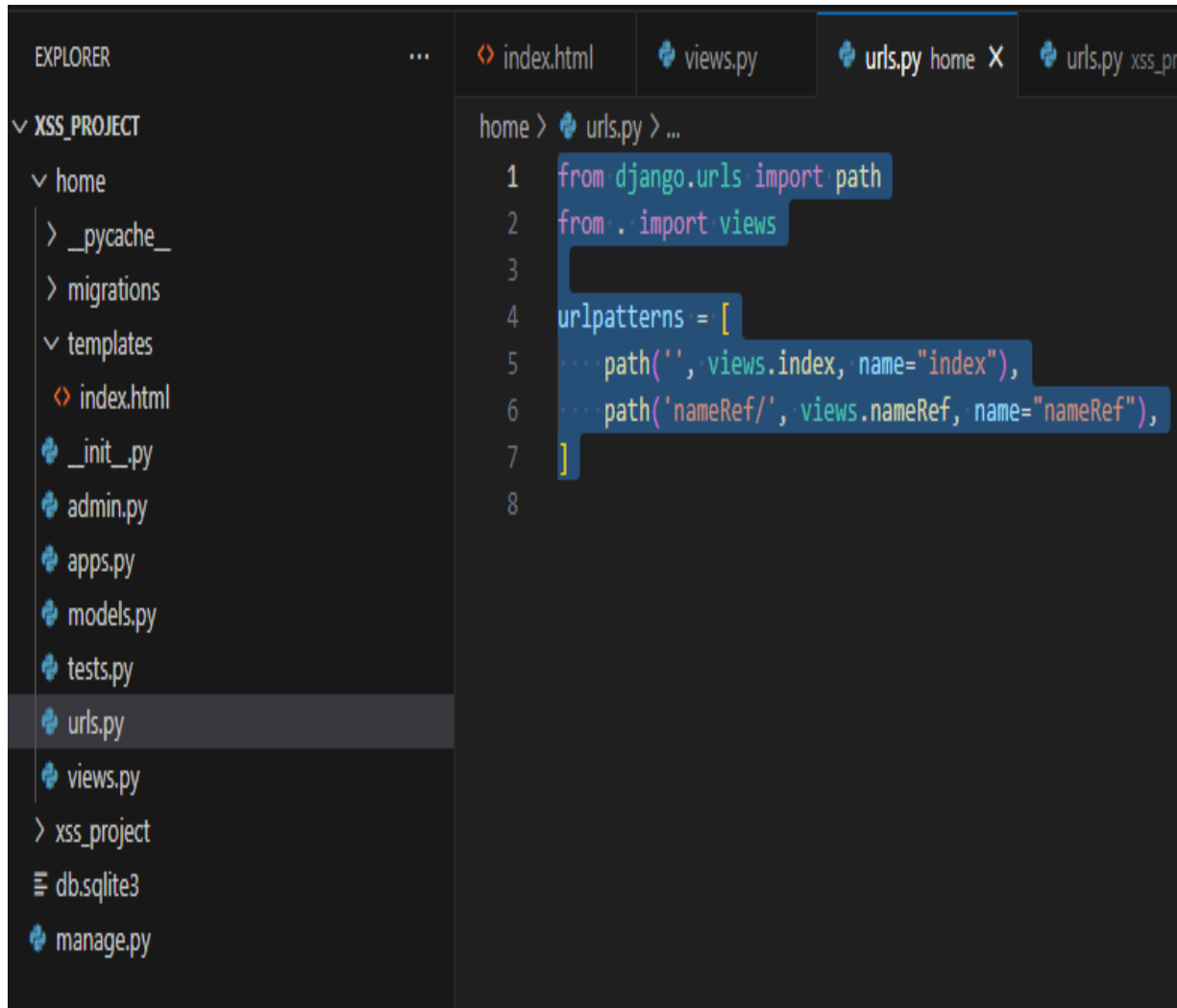
```
def nameRef(request):
    if request.method == "POST":
        name = request.POST.get("name")
        if not name:
            return HttpResponse("Please enter your name.")
```

```
        name1 = name.lower()
```

```
        if "script" in name1:
            # Replace "script" with empty string
            name2 = name1.replace("script", "")
            return HttpResponse(name2)
```

```
        else:
            return HttpResponse(name1)
```

```
    else:
        return HttpResponse("Please Enter your name.")
```



The screenshot shows a code editor with a file explorer on the left and a code editor on the right. The file explorer shows a project named 'XSS_PROJECT' with a subfolder 'home'. Inside 'home', there are files like '_pycache_', 'migrations', 'templates', 'index.html', '_init_.py', 'admin.py', 'apps.py', 'models.py', 'tests.py', 'urls.py' (selected), and 'views.py'. The code editor shows the content of 'urls.py' with the following code:

```
home > urls.py > ...
1 from django.urls import path
2 from . import views
3
4 urlpatterns = [
5     path('', views.index, name="index"),
6     path('nameRef/', views.nameRef, name="nameRef"),
7 ]
8
```

App folder home: **urls.py**:

```
from django.urls import path
from . import views
```

```
urlpatterns = [
    path("", views.index, name="index"),
    path('nameRef/', views.nameRef, name="nameRef"),
]
```

python manage.py runserver

```
September 15, 2025 - 16:41:56
Django version 5.2.6, using settings 'xss_project.settings'
Starting development server at http://127.0.0.1:8000/
Quit the server with CTRL-BREAK.
```

← → ↻ ⓘ 127.0.0.1:8000

Cross Site Scripting

Name:

← → ↻ ⓘ 127.0.0.1:8000

Cross Site Scripting

Name:

← → ↻ ⓘ 127.0.0.1:8000/nameRef/

sit

← → ↻ ⓘ 127.0.0.1:8000

Cross Site Scripting

Name:

← → ↻ ⓘ 127.0.0.1:8000/nameRef/

Network Infrastructure Poisoning

- Attackers exploit vulnerabilities in **network infrastructure (core Internet services)**, particularly **DNS servers**, to disrupt or manipulate internet traffic.
- DNS (Domain Name System)- is like the Internet's phonebook: it translates human-friendly website names (e.g., JosephSteinberg.com) into numeric IP addresses (e.g., 104.18.45.53).
- **How Attacks Work:**
 - Criminals insert incorrect or corrupt DNS data into DNS servers.
 - This causes the DNS server to return a wrong IP address when users try to visit a website.
 - As a result, users are redirected to fake or malicious sites controlled by the attacker.

Example: DNS Poisoning (also called Pharming)

- User types in a legitimate bank website URL.
- DNS server returns the IP address of a fake site set up by the attacker.
- User unknowingly interacts with the fraudulent site, potentially exposing sensitive information like login credentials.

Network Infrastructure Poisoning

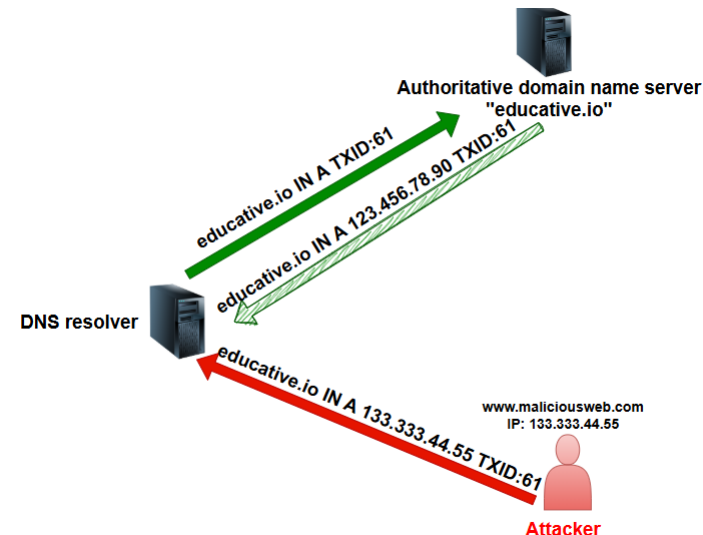
Other Network Infrastructure Attacks:

- Redirecting traffic to unintended destinations (reroute network traffic)
- Capturing data in transit (eavesdropping).
- Causing denial-of-service (DoS) to disrupt access.

Why This Happens:

- The Internet's infrastructure is complex and was not originally designed with security as a priority. This makes it vulnerable to a wide range of attacks.

Ex: Kaminsky attack in DNS



Malvertising (Malicious Advertising)

- Malvertising is the use of **online advertisements** to deliver **malware** or launch **cyberattacks**.
- malicious code is hidden inside online advertisements to spread malware or exploit users without needing to hack the host website directly.
- Types of Malvertising Attacks:
 - Click-based: Malware activates only when the user clicks an ad.
 - Drive-by infections: The system is compromised just by loading the ad, requiring no interaction.



Malvertising (Malicious Advertising)

Why It's Effective

- Website owners want ads that attract clicks to earn revenue. Attackers exploit this to place malicious ads without needing to hack the actual website.
- Third-party ad networks: Even secure websites rely on external ad suppliers, making malvertising hard to block.
- Trusted platforms: Reputable websites unknowingly host malicious ads, making users more likely to trust and click them.
- Large reach: Cybercriminals can spread malware to millions of users without directly breaching popular websites.

• How Malvertising Works

- Attackers create ads that look legitimate but contain hidden malicious code.
- These ads are placed on ad networks, which distribute them to multiple websites.
- When a user visits a site displaying the ad, the malware can either:
 - Infect the device automatically (drive-by download).
 - Trick the user into clicking the ad, leading to a malicious site or download.

Drive-by Downloads

- Software downloaded by a user without their full understanding or consent.
- Types:
- **Automatic infections/ Unintentional download:** Visiting a compromised website that automatically delivers malware to the device.
- **Deceptive downloads/ Tricked into downloading:** Users are tricked into believing they are installing something harmless (e.g., a fake security patch) when in reality it delivers malware.
 - EX: a security vulnerability is present on his or her computer and that tells the user to click on a button that says Download to install a security patch

Common Ways Criminals Steal Passwords

1. Theft of Password Databases

- Criminals hack into websites or services to steal password databases.
- If passwords are not properly encrypted (hashed and salted (Salt is a random string added to a password before hashing.)), they can be quickly used.
- Even encrypted databases can be cracked using **hash attacks** .
- This is **one of the most common** ways passwords are compromised.

2. Social Engineering Attacks

- Involves **tricking people** into giving up their passwords.
- Example: A criminal pretends to be IT support and convinces someone to reset a password.
- **Phishing** is a common type of social engineering.

3. Malware

- If malware is installed on a device, it can record keystrokes or steal saved passwords.

Common Ways Criminals Steal Passwords

4. Credential Attacks

- These use automated or targeted methods to guess passwords.

Types:

- **Brute Force:** Tries every possible password.
- **Dictionary Attack:** Tries common words and phrases (Uses a list of common passwords or dictionary words).
- **Calculated Attack:** Uses personal info (e.g., from social media) to guess passwords.
- **Blended Attack:** Mixes techniques, like using common patterns or names.

5. Network Sniffing

- On insecure networks (like public Wi-Fi), passwords sent without encryption can be **intercepted**.

6. Credential Stuffing

- Reuses stolen username-password combos from one site to try to log into another.
- Exploits the fact that many users **reuse passwords** across multiple services.

Exploiting Maintenance Difficulties

Maintenance difficulties are the **challenges and obstacles encountered** in keeping computer systems and software operating efficiently and securely.

- **Maintenance is complex**

- Systems are made of many interdependent components.
- Updating one piece may cause problems in others.

- **Patching delays introduce risk**

- Vendors release patches to fix bugs, but users/admins often delay applying them due to compatibility or operational concerns.
- Attackers exploit these unpatched vulnerabilities.

- **Automatic updates aren't a silver bullet**

- They happen periodically, not in real-time (not every second of every day,).
 - Not all applications support automatic updates.
 - Even with automation, systems may lag behind.

- **Updates can break things**

- Installing a patch might cause another program to fail or even open new vulnerabilities.
- This makes admins hesitant to patch immediately.

Advanced Attacks

Advanced cyber attacks fall into two main categories: **opportunistic** and **targeted attacks**

Opportunistic	Targeted attacks
Broad – attacks as many systems as possible	Narrow – focuses on specific victims
No predefined targets; any vulnerable system is a target	Predefined targets (specific org, person, or system)
Mostly financial gain (e.g., stealing credit cards, ransomware)	Espionage, sabotage, revenge, data theft, strategic advantage
May not try to hide breach	Highly stealthy, wants to avoid detection
Uses common, publicly known exploits and automated tool	Often uses advanced methods, custom exploits, sometimes zero-days

Advanced Attacks

Some advanced threats that are used in targeted attacks are described as **advanced persistent threats (APTs)**:

Advanced:

- Uses sophisticated hacking techniques (e.g., zero-day exploits, custom malware).
- Often backed by large budgets and research & development.

Persistent:

- Adversary is determined and keeps trying until they breach the target.
- They focus only on the chosen target, not on random systems.
- Maintain long-term presence once inside.

Threat:

- Capable of inflicting serious damage (data theft, espionage, sabotage).
- May remain undetected for months or years.

Ex: Stuxnet (2010) – attacked Iran's nuclear program.

Advanced Attacks

Blended (Opportunistic + Targeted) Attacks

- A blended attack is in-between opportunistic and targeted attacks.
- The attacker doesn't go after everyone (like opportunistic), but also doesn't pick one specific victim (like targeted).
- Instead, the attacker chooses a group of victims that share something valuable.

Example:

If a hacker wants credit card numbers, they will attack many retail sites that store such data (like Walmart, Best Buy, or Barnes & Noble).

They don't care which store they hack, as long as they get credit card data.

Attacking sites that don't have credit card info would be a waste of time.